TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Ivanti Connect Secure exploit chain gets two more flaws added to CISA KEV

From **Cybersecurity Briefing - 2026-10-31** · 2026-10-30 to 2026-10-31 (global, US, industry; some items from 2026-10-28 and 2026-10-29 where primary reporting landed in the window). Indiana sections: 2026-10-26 to 2026-10-31. · Briefing generated 2026-10-31

REPORT ID	VERSION	HANDLING
CTI-20261102-01	1.0 · 2026-11-02 10:40 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-30	2026-10-31
CVES	**ANALYST**	
CVE-2026-104935 (CVSS 8.6), CVE-2026-111357 (CVSS 8.8), CVE-2026-118527 (CVSS 4.3)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CISA added CVE-2026-111357 (privilege escalation) and CVE-2026-118527 (predictable identifier, file upload to a known location) to the KEV catalog on 2026-10-30, joining CVE-2026-104935 (authentication bypass), which was listed on 2026-10-13 [S4] [S5]. Together they give an unauthenticated attacker root command execution on Ivanti Connect Secure (ICS) VPN appliances. Volexity found the chain while investigating a customer's appliance running 22.8R2.4, which was fully patched at the time, and attributes it to a previously unknown actor it tracks as UTA0576 [S2]. Defused reports decoy hits from 2026-10-01 and Volexity's first observed exploitation is 2026-10-03, so this was a true zero-day before Ivanti's 2026-10-13 disclosure [S2] [S10].

The rating of Critical reflects the chain and not any single score: the individual CVSS scores are 8.6, 8.8 (7.0 in the CVE record) and 4.3 [S1] [S7]. The actor left no web shell, backdoor or first-stage malware. It re-ran the full chain for every command, took results back in HTTPS responses, patched a library only in memory, and rewrote the debug and audit logs to remove its entries [S2]. CISA warns that Ivanti's Integrity Checker Tool may not detect this activity and that network and memory forensics are needed to assess compromise [S6]. The objective was credentials: stored LDAP credentials, LAPS passwords, BitLocker recovery keys, captured LDAP, HTTP Basic and NTLM material, and password spraying against Active Directory. Volexity assesses with high confidence that this was preparation for lateral movement [S2] [S14].

Fixes for the two new CVEs shipped on or about 2026-10-29 in 25.1.1.3 and 22.8R2.6, and anyone who installed the earlier 25.1.1.2 or 22.8R2.5 fix for CVE-2026-104935 has to upgrade again [S9]. Ivanti says a limited number of customers were affected and gives no count [S9] [S13]. Shadowserver tracks more than 5,000 exposed ICS instances, with no data on how many are secured [S10]. Honeypot operator Previdian logged 105 exploitation attempts from 50 addresses by 2026-10-14, so exploitation of the entry point is no longer limited to one actor's targets [S12]. The briefing excerpt said the RCE link has no CVE named in coverage; Volexity and other reporting place the authentication bypass and the RCE together under CVE-2026-104935 [S2] [S14].

Upgrade every appliance to a fixed build, and treat upgrade as the start of the work. If an appliance was internet-exposed and unpatched at any point since late September, capture memory and network evidence before resetting it, hunt for the indicators below, and assume credentials held by or passing through the appliance may be stolen. Federal due dates are 2026-11-02 for CVE-2026-111357 and 2026-11-13 for CVE-2026-118527; the 2026-10-16 date for CVE-2026-104935 has passed [S4]. CISA's KEV entries mark forensic triage as required for CVE-2026-104935 and CVE-2026-111357 [S4]. We could not read Ivanti's own advisory because the page did not render, so version details here come from CISA, the Canadian Centre for Cyber Security and press reports of the advisory [S6] [S9] [S15].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Opportunistic exploitation of CVE-2026-104935 will very likely continue against unpatched appliances over the next 30 days, given honeypot activity from many addresses, an automatable entry point and a very high EPSS score. [S8] [S12] [S13] [S17]

LIKELY · MODERATE CONFIDENCE
The true number of compromised organizations is likely larger than Ivanti's 'limited number' suggests, because exploitation predates disclosure by at least 12 days, the tool most customers would check is blind to the chain, and the actor removes log entries. [S2] [S6] [S9] [S10]

LIKELY · MODERATE CONFIDENCE
Credentials stolen from appliances will likely be used after those appliances are patched wherever passwords, LAPS secrets and BitLocker keys are not rotated, since patching does nothing to invalidate stolen material. [S2] [S6]

LIKELY · LOW CONFIDENCE
A meaningful share of organizations that patched on or after 2026-10-13 will likely remain on 25.1.1.2 or 22.8R2.5 for some weeks because they consider the issue closed, leaving the root escalation available to any attacker with another foothold on the appliance. [S9]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that this chain or credentials stolen through it will be publicly tied to a ransomware or extortion intrusion within 90 days. Motivation is assessed as criminal only at low confidence, and KEV lists ransomware use as unknown, but ransomware crews have used a sizable share of exploited Ivanti flaws. [S2] [S4] [S10]

INDICATORS OF COMPROMISE

Almost all indicators come from Volexity's single incident investigation published 2026-10-13, whose GitHub IOC file contains only one IP [S2] [S3]. The four additional IPs are honeypot sources from Previdian via The Hacker News and are not tied to UTA0576 [S12]. The one SHA-256 is unexplained and low trust. IP indicators will age quickly; the HTTP header and on-appliance artifacts are more durable, though the actor removes many of its own files.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`108[.]165[.]147[.]64`	UTA0576 exploitation IP, an Evoxt VPS. Ran an OpenVPN server from 2026-09-30 to 2026-10-07.	REPORTED	2026-09-30	[S2] [S3]
ipv4	`216[.]73[.]160[.]59`	Exploitation attempts against Previdian honeypots, recorded by 2026-10-14. Not attributed to UTA0576. Exact dates not published.	REPORTED		[S12]
ipv4	`216[.]73[.]160[.]61`	Exploitation attempts against Previdian honeypots, recorded by 2026-10-14. Not attributed to UTA0576. Exact dates not published.	REPORTED		[S12]
ipv4	`216[.]73[.]160[.]210`	Exploitation attempts against Previdian honeypots, recorded by 2026-10-14. Not attributed to UTA0576. Exact dates not published.	REPORTED		[S12]
ipv4	`45[.]8[.]19[.]111`	Exploitation attempts against Previdian honeypots, recorded by 2026-10-14. Not attributed to UTA0576. Exact dates not published.	REPORTED		[S12]
sha256	`25b95f47359c327e3a5ae5ac5cd147f8d9afd98092faf136822ee287e25e3dc8`	LOW TRUST. Appears only in the Ampcus write-up, unlabeled beside the Volexity IP, with no file name or origin given. Not in Volexity's post or IOC file, and we could not corroborate it. Use for lookups only, not as evidence of compromise.	REPORTED		[S16]
http-request	`/dana-na/auth/url_default/welcome.cgi`	Public login path used as the entry point. Legitimate on its own; high request volume or the header below is the signal.	REPORTED	2026-10-03	[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`X-DSCGI-PATH: /home/webserver/htdocs/dana/fb/smb/wu.cgi`	Header routes a request for the public login script to the protected upload handler, bypassing the access check.	REPORTED	2026-10-03	[S2]
http-request	`X-DSCGI-PATH: /home/runtime/tmp/<MD5(filename)>`	Parallel requests that try to execute the uploaded file during the race window before it is deleted.	REPORTED	2026-10-03	[S2]
http-request	`Mismatch between URL path and X-DSCGI-PATH header value`	Volexity advises flagging any mismatch because other paths may be abused. Inbound presence of the header is also listed as an indicator in honeypot reporting.	REPORTED		[S2] [S12]
other	`Perl script uploaded with a .zip file name to wu.cgi`	Handler writes the upload to disk before validating it as a ZIP. Honeypot variants return unique markers to confirm code execution.	REPORTED	2026-10-03	[S2] [S12]
filepath	`/home/runtime/tmp/<MD5(filename)>`	Temporary location of the uploaded script. Short-lived because the handler deletes it after failed validation.	REPORTED		[S2]
filepath	`/home/runtime/tmp/ics-root-run-inband-*.pl`	Root execution script removed by the actor's cleanup; may be recoverable forensically.	REPORTED		[S2]
filepath	`/home/runtime/tmp/ics-root-result-inband-*`	Root command output file removed by the actor's cleanup.	REPORTED		[S2]
filepath	`/tmp/ml.py`	Part of a custom LDAPv3 tool and script pair used to search AD for LAPS passwords, BitLocker data and password attributes. Volexity does not say which file of the pair is which.	REPORTED		[S2]
filepath	`/tmp/rq5.py`	Part of the same LDAP tool and script pair; listed among files the actor removes.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/tmp/mk.py`	Custom Python Kerberos implementation with Kerberoasting functionality.	REPORTED		[S2]
filepath	`/tmp/rr.py`	Uses mk.py to test credentials; removed by the actor's cleanup.	REPORTED		[S2]
filepath	`/tmp/pu.txt`	Usernames extracted from log.events.vc0.	REPORTED		[S2]
filename	`sp_run.py`	Helper script for password spraying AD accounts.	REPORTED		[S2]
filepath	`/tmp/sp_out.txt`	Password spray output.	REPORTED		[S2]
filepath	`/tmp/spray_hits.json`	Password spray successes.	REPORTED		[S2]
filepath	`/data/.icscap/dsstatmond`	Renamed tcpdump running from a hidden directory, with a filter for plaintext protocol ports such as LDAP, HTTP, FTP and Telnet.	REPORTED		[S2]
filepath	`/data/.icscap/h.py`	Parser that pulls LDAP credentials, HTTP Basic credentials and NTLM challenge-response material from captures.	REPORTED		[S2]
filepath	`/data/.icscap/cap0`	Packet capture file; the actor parsed it for TCP 389 traffic and exfiltrated its first 8 KB.	REPORTED		[S2]
filepath	`/data/.icscap/cap*`	Capture file glob read by h.py. Eight files rotate, so older captures are overwritten.	REPORTED		[S2]
filepath	`/home/lib/libdsplibs.so`	LEGITIMATE file. Its in-memory copy in the cgi-server process is patched and later restored; the on-disk file is unchanged. Do not treat its presence as an indicator.	REPORTED		[S2]
filepath	`/home/bin/updateOpswatSDK.pl`	LEGITIMATE script. Its DSCache task entry is temporarily changed so dsinvoked runs Perl instead, then restored. Do not treat its presence as an indicator.	REPORTED		[S2]
other	`DSCache entry ScriptUtil/updateOpswatSDK launching the Perl interpreter`	Mechanism for root execution through dsinvoked. Observable only if caught before the entry is restored, for example in a memory image.	REPORTED		[S2] [S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/home/runtime/dlogs/debuglog`	LEGITIMATE log rewritten by the actor to remove a time window. Look for gaps compared with off-box copies.	REPORTED		[S2]
filepath	`/var/log/audit/audit.log`	LEGITIMATE log rewritten by the actor to remove a time window. Look for gaps compared with off-box copies.	REPORTED		[S2]
filename	`log.events.vc0`	LEGITIMATE log file parsed by the actor for usernames. Not described as altered.	REPORTED		[S2]
port	`389/tcp`	LDAP traffic targeted in the capture parsing. Plaintext binds through the appliance are exposed. Normal port, so use it only as hunting context.	REPORTED		[S2]
other	`YARA rule exploit_log_ivanti_rce`	Volexity rule for files or memory regions containing the crafted request headers.	REPORTED	2026-10-13	[S3]
other	`YARA rule exploit_py_ivanti_oct26`	Volexity rule for process memory containing the Python privilege escalation exploit used by UTA0576.	REPORTED	2026-10-13	[S3]
filepath	`/data/.icscap/cap1 through /data/.icscap/cap7`	Inferred from Volexity's description of eight rotating capture files with a first file named cap0. Exact names beyond cap0 are not stated by Volexity.	DERIVED		[S2]
filepath	`/home/runtime/tmp/[0-9a-f]{32}`	Regex form of the upload path. An MD5 hex digest is 32 characters, so a file with this name pattern in forensic images fits the described handler behavior. Could match benign temporary files.	DERIVED		[S2]
command	`cgi-server > perl > bash > python (exec of Base64 and zlib payload)`	Process lineage inferred from the staged Perl, Bash and Python execution in the cgi-server context. Useful for memory or process analysis; no command line was published.	DERIVED		[S2]
command	`dsinvoked > perl`	Inferred from dsinvoked being made to run Perl instead of the legitimate maintenance script. A Perl interpreter started with no script argument matching /home/bin/updateOpswatSDK.pl would be suspicious.	DERIVED		[S2]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker sends a request to the public login script with an X-DSCGI-PATH header naming a protected CGI. The access check reads the URL but routing follows the header, so the upload handler wu.cgi is reachable without authentication. The attacker uploads a Perl script named as a .zip; the handler writes it to a predictable path based on the MD5 of the file name before validating it, and parallel requests execute it during the short window before deletion. That gives code execution in the cgi-server context, staged through Perl, Bash and an in-memory Python payload. The Python code then patches libdsplibs.so in memory and alters a DSCache task entry so the root-privileged dsinvoked service runs Perl, after which it restores both. Commands and output travel inside the exploit's HTTPS traffic and the entire chain repeats for each command, so nothing persistent is left. After that the actor harvested LDAP credentials, queried AD for LAPS and BitLocker data, captured traffic with a renamed tcpdump, sprayed passwords, and filtered the debug and audit logs [S2] [S14]. The mapping of CVE-2026-118527 to the predictable upload path is our inference from the KEV description; Ivanti's mapping could not be read directly [S4].

Threat actor

UTA0576

Attribution confidence: Low · **Motivation:** Assessed as criminal rather than espionage, at low confidence. The ultimate goal is unknown. · **Suspected origin:** Unknown

Name is Volexity's tracking label for a previously unknown cluster, and no link to a known group is established. Volexity notes a similar packet-capture technique used by UTA0533 against SonicWall SMA appliances but does not link the two. It assesses with medium confidence that the actor used large language models for exploit development and post-exploitation tooling [S2]. Some press reports state financial motivation without carrying the low-confidence caveat [S12]. Later opportunistic attempts seen by honeypots should not be assumed to be this actor.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Authentication bypass through X-DSCGI-PATH on welcome.cgi, then a race on the wu.cgi upload to run code. [S2] [S8]	Inspect decrypted HTTP for the header and high request volume to welcome.cgi from one source.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Uploaded Perl script runs a Bash script as the second stage. [S2]	Memory forensics of process trees; appliance telemetry is limited.

Tactic	Technique	Procedure observed	Detection opportunity
Execution	T1059.006 Command and Scripting Interpreter: Python	Python payload run through exec(), plus custom Python tools written to /tmp. [S2] [S3]	Apply Volexity's YARA rules to memory images and check /tmp for the listed files.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	In-memory library patch allows a DSCache change so dsinvoked runs Perl as root; the exploit tests success by reading /etc/shadow. [S2] [S3] [S7]	Memory image review with exploit_py_ivanti_oct26. The Integrity Checker Tool will not see it.
Defense Evasion	T1027 Obfuscated Files or Information	Python payload is Base64-encoded and zlib-compressed. AD results are stored the same way as JSON. [S2]	Look for encoded blobs in decrypted HTTP request bodies and in /tmp on forensic images.
Defense Evasion	T1070.002 Indicator Removal: Clear Linux or Mac System Logs	Filters and rewrites debuglog and audit.log to drop entries in a time window while keeping older records. [S2]	Compare on-box logs with syslog forwarded to a SIEM and look for time gaps.
Defense Evasion	T1070.004 Indicator Removal: File Deletion	Removes ics-root-* files and scripts such as /tmp/rq5.py and /tmp/rr.py. [S2]	Disk forensics for deleted file remnants.
Defense Evasion	T1036.003 Masquerading: Rename Legitimate Utilities	tcpdump renamed to dsstatmond to resemble an appliance daemon. [S2]	Look for a dsstatmond process or file under /data/.icscap/.
Defense Evasion	T1564.001 Hide Artifacts: Hidden Files and Directories	Tools and captures kept in the hidden /data/.icscap directory. [S2]	Check for the directory on disk images or through Ivanti support-assisted collection.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Extracts LDAP domain credentials stored on the appliance and collects configuration files. [S2]	Hard to see on the appliance; watch for the service account used from unusual contexts or for unusual queries.
Credential Access	T1040 Network Sniffing	Rotating packet captures parsed for LDAP, HTTP Basic and NTLM material. [S2]	Hunt for the capture files and process; review plaintext LDAP use.
Credential Access	T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting	mk.py contains Kerberoasting functionality. Actual roasting use is not clearly confirmed by Volexity's description. [S2]	Event 4769 with RC4 tickets requested from the appliance's internal IP or service account.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1110.003 Brute Force: Password Spraying	sp_run.py sprays AD accounts using usernames harvested from appliance logs. [S2]	Many accounts with failed logons (4625, 4771) from the appliance's internal IP.
Defense Evasion	T1078.002 Valid Accounts: Domain Accounts	Authenticates to a domain controller with the appliance's AD service account. [S2]	Baseline the account's LDAP activity and alert on directory-wide searches.
Discovery	T1087.002 Account Discovery: Domain Account	LDAP queries for accounts and attributes including userPassword, unixUserPassword, LAPS and BitLocker data, and logon script paths. [S2] [S14]	Directory auditing on confidential attributes (event 4662, needs a SACL) and LDAP query logging on domain controllers.
Discovery	T1016 System Network Configuration Discovery	Reads /etc/resolv.conf and resolves internal domains. [S2]	DNS logs showing unusual internal lookups from the appliance.
Collection	T1005 Data from Local System	Collects configuration from /home/etc/pulse/, /home/etc/, /home/*.cfg and /home/runtime. [S2]	Unusually large HTTPS responses from the appliance login path.
Command and Control	T1071.001 Application Layer Protocol: Web Protocols	Commands and output travel in the exploit's own HTTPS requests and responses to the appliance. [S2]	No outbound beacon to find. Focus on inbound request patterns and response sizes.
Exfiltration	T1041 Exfiltration Over C2 Channel	Results, configuration and the first 8 KB of a capture returned over the same HTTPS channel. [S2]	Review response sizes for requests to welcome.cgi from single sources.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Inbound X-DSCGI-PATH header to Connect Secure login script `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"Possible Ivanti Connect Secure CVE-2026-104935 X-DSCGI-PATH
request"; flow:established,to_server; http.uri; content:"/dana-na/auth/url_default/welcome.cgi";
http.header; content:"X-DSCGI-PATH|3a|"; nocase; classtype:web-application-attack; sid:9104935; rev:1;)
```

Sees only decrypted traffic, so it needs a TLS-terminating proxy or inspection point in front of the appliance. Change the sid to fit your local range.

Header abuse and request bursts in proxy or WAF logs `SPLUNK SPL`

```
index=proxy OR index=waf uri_path="/dana-na/auth/url_default/welcome.cgi"
| eval hdr=coalesce(x_dscgi_path, 'http_x_dscgi_path')
| eval suspicious=if(isnotnull(hdr), 1, 0)
| bin _time span=5m
| stats count AS requests sum(suspicious) AS header_hits values(hdr) AS header_values BY _time src_ip
dest
| where header_hits > 0 OR requests > 100
| sort - header_hits requests
```

Field names depend on your logging, and many deployments do not log this custom header at all. The threshold of 100 requests is a starting point; the race condition implies bursts of parallel requests. Tune it against normal login traffic.

AD abuse from the VPN appliance internal address `KQL`

```
let ApplianceIPs = dynamic(["<ics_internal_ip_1>", "<ics_internal_ip_2>"]);
SecurityEvent
| where TimeGenerated > ago(45d)
| where EventID in (4625, 4771, 4769)
| where IpAddress has_any (ApplianceIPs)
| extend IsRc4Ticket = EventID == 4769 and TicketEncryptionType == "0x17"
| summarize Events = count(), Accounts = dcount(TargetUserName), Rc4Tickets = countif(IsRc4Ticket),
Failures = countif(EventID in (4625, 4771)), First = min(TimeGenerated), Last = max(TimeGenerated) by
IpAddress, bin(TimeGenerated, 1h)
| where Failures > 10 or Rc4Tickets > 0 or Accounts > 20
```

Run against domain controller logs, which the actor cannot rewrite from the appliance. Populate the appliance IPs by hand. Some column names may need adjusting for your schema because they can sit inside EventData.

Traffic involving reported source IPs `SPLUNK SPL`

```
index=firewall OR index=proxy (src_ip IN ("108.165.147.64", "216.73.160.59", "216.73.160.61",
"216.73.160.210", "45.8.19.111") OR dest_ip IN ("108.165.147.64", "216.73.160.59", "216.73.160.61",
"216.73.160.210", "45.8.19.111")) earliest=-45d
| stats count min(_time) AS first max(_time) AS last values(dest_port) AS ports BY src_ip dest_ip
| convert ctime(first) ctime(last)
```

A hit from the Volexity IP warrants incident response. A hit from the honeypot IPs shows targeting only and does not show this actor or a successful exploit. A clean result proves little, because 50 addresses were seen by one honeypot operator and only four were published.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Ivanti Connect Secure	25.1.1.1 and prior; 25.1.2.2 and prior; 22.8R2.4 and prior. 22.7R2.14 and prior are stated as not affected.	25.1.1.2; 22.8R2.5; 25.1.3.0 and 25.1.3.1 listed as unaffected. These builds still need the later fixes below.	CVE-2026-104935	8.6 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L)	0.868 (99.7th percentile, 2026-11-02)	Yes (added 2026-10-13)	2026-10-16
Ivanti Connect Secure	25.1.1.2 and prior; 22.8R2.5 and prior. CISA's combined chain list also includes 25.1.2.2 and prior. The CVE record names only 22.8R2.4.	25.1.1.3; 22.8R2.6. Canadian Centre lists before 25.1.3.1 as affected for the 25.1.3 line. Confirm in Ivanti's advisory.	CVE-2026-111357	8.8 in press reports of the advisory; 7.0 in the CVE record (AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H)	0.005 (45.0th percentile, 2026-11-02). Understates risk because this is a chain link.	Yes (added 2026-10-30)	2026-11-02

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Ivanti Connect Secure	25.1.1.2 and prior; 22.8R2.5 and prior. CISA's combined chain list also includes 25.1.2.2 and prior.	25.1.1.3; 22.8R2.6. Canadian Centre lists before 25.1.3.1 as affected for the 25.1.3 line. Confirm in Ivanti's advisory.	CVE-2026-118527	4.3 in press reports of the advisory; CVE record could not be retrieved	No score returned on 2026-11-02	Yes (added 2026-10-30)	2026-11-13

Immediate (0–24 hours)

- Inventory every Connect Secure appliance and cluster member, including virtual and cloud instances, and confirm the running version in the admin console. Anything on 25.1.1.2 or 22.8R2.5 counts as unfinished, even if it was patched in October. `IT OPS` [S6] [S9]
- Before resetting or rebooting any appliance that was exposed while vulnerable, capture memory and preserve network and disk evidence. The chain lives in memory, so a reboot or upgrade can destroy the best evidence. `SOC` [S2] [S6]
- Upgrade to 25.1.1.3 or 22.8R2.6, or the fixed build for your branch per Ivanti's upgrade guide. For 25.1.3 confirm 25.1.3.1 or later against the advisory. For 25.1.2 follow Ivanti's upgrade guide, because no fixed 25.1.2 build was confirmed. `IT OPS` [S1] [S6] [S9] [S15]
- Hunt proxy, WAF and firewall logs back to at least 2026-09-30 for the X-DSCGI-PATH patterns, high request volume to welcome.cgi, and the reported IPs. `SOC` [S2] [S3] [S12]
- Do not accept a clean Integrity Checker Tool result or clean appliance logs as proof of safety. Record triage as open until network and memory review is done. `SOC` [S2] [S6]

Short term (1–7 days)

- Check forensic images for /tmp artifacts and the /data/.icscap directory, and run Volexity's YARA rules against memory captures. `SOC` [S2] [S3]
- If compromise is suspected, follow CISA's recovery order: back up the configuration, factory reset and upgrade (rebuild for cloud and virtual), restore the configuration, reset all domain, administrator and local passwords, revoke and reissue stored certificates, and reset API keys and license server credentials. `IT OPS` [S6]
- If compromise is confirmed or cannot be excluded, reset the appliance's AD service account, LAPS passwords and BitLocker recovery keys, and force resets for users whose credentials could have passed through the appliance in cleartext or as NTLM material. `IT OPS` [S2] [S6]

- Review domain controller logs for password spraying, RC4 service ticket requests and unusual LDAP searches from the appliance's internal IP, and compare on-box debug and audit logs with forwarded copies for gaps. `SOC` [S2]
- Where compromise is confirmed, engage counsel, cyber insurer and an incident response provider early to assess notification duties, including under Indiana's breach notification law and HIPAA where applicable. `LEADERSHIP` [S2] [S6]

Long term

- Move off the 22.8 branch before it reaches end of life on 2027-01-31, and budget the migration now. `IT OPS` [S6]
- Reassess reliance on this VPN platform given repeated zero-days and KEV listings. Compare the cost of staying against moving to a replacement remote access design with stronger isolation. `LEADERSHIP` [S10] [S12]
- Reduce what an edge appliance can give away: use a least-privilege directory account with no rights to read LAPS or BitLocker attributes, require LDAPS instead of plaintext LDAP, and store as few secrets as possible on the device. `IT OPS` [S2]
- Send appliance logs off-box in real time, and put HTTP header logging or TLS inspection in front of edge appliances where supported, so an attacker on the box cannot erase the only record. `SOC` [S2]

Workarounds & compensating controls

- If an upgrade cannot happen right away, take the appliance off the internet or stop using it. CISA's KEV action points to discontinuing use when mitigations are unavailable. No vendor workaround was identified in the sources we could read. `LEADERSHIP` [S4]
- As a temporary measure, block or strip X-DSCGI-PATH at an upstream reverse proxy or WAF that terminates TLS and limit request rates to welcome.cgi. This is our suggestion derived from the bypass mechanism, is not vendor-approved, and does not replace patching. Test it against normal logins first. `IT OPS` [S2]
- Restrict VPN portal access to known source ranges where the user base allows, and block the reported IPs, recognizing that the IPs have limited lasting value. `IT OPS` [S2] [S12]
- Put targeted alerting on the appliance's AD service account and internal IP until triage finishes. `SOC` [S2]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Attackers chain three Ivanti Connect Secure flaws (KEV additions and Ivanti statements)
Published 2026-10-31 · `B2` Usually reliable, probably true
Briefing's source item. Contains no IOCs.

[S2] Volexity: A Series of Unauthenticated Events: Chained Exploitation of Ivanti Connect Secure Zero-Days
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
Primary research from one incident. Updated 2026-10-29 with the privilege escalation fix. Body text not rewritten after the update.

[S3] Volexity (GitHub): threat-intel repository, 2026-10-13 Ivanti: iocs.csv and rules.yar
Published 2026-10-13 · **A2** Completely reliable, probably true
Primary indicators. One IP and two YARA rules. Publication date inferred from the folder name.

[S4] CISA: Known Exploited Vulnerabilities Catalog, version 2026.10.30
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Primary source for KEV dates, due dates, CWEs, ransomware field and forensic triage field.

[S5] CISA: CISA Adds Two Known Exploited Vulnerabilities to Catalog
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Cites BOD 26-04.

[S6] CISA: CISA Urges Patching Newly Exploited Vulnerabilities in Ivanti Connect Secure
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
Revised 2026-10-30. Source for affected versions, forensic triage and recovery steps.

[S7] CVE Program: CVE record CVE-2026-111357
Published 2026-10-15 · **A3** Completely reliable, possibly true
Published before Ivanti's advisory update. Score, CWE and version list differ from KEV and press reports of the advisory.

[S8] CVE Program: CVE record CVE-2026-104935
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
CVSS vector, CWE-290, unaffected versions, SSVC automatable marking.

[S9] SecurityWeek: Ivanti Patches Two More Zero-Days Exploited in Connect Secure Attack Chain
Published 2026-11-02 · **B2** Usually reliable, probably true
Best available relay of Ivanti's updated advisory and statements.

[S10] BleepingComputer: Ivanti patches two more Connect Secure zero-days chained in attacks
Published 2026-11-02 · **B2** Usually reliable, probably true
Shadowserver exposure figure over 5,000, Ivanti KEV count and ransomware count.

[S11] BleepingComputer: Ivanti warns of Connect Secure zero-day exploited in attacks
Published 2026-10-13 · **B2** Usually reliable, probably true
Original disclosure coverage. Shadowserver figure over 5,500. Publication date taken from the article's reference to the Tuesday warning.

[S12] The Hacker News: CISA Urges Immediate Ivanti Connect Secure Updates as Honeypots Log 105 Exploit Attempts
Published 2026-10-14 · **B3** Usually reliable, possibly true
Only available source for Previdian honeypot IPs. Original Previdian data not located.

[S13] CyberScoop: Ivanti misses opportunity to fix vulnerability before attackers got to work and made it a zero-day
Published · **B2** Usually reliable, probably true
Ivanti's June discovery and release-cycle decision, researcher comments. Attributes the October 1 date to Volexity, unlike other sources. Publication date not captured.

[S14] Help Net Security: Attackers chained three Ivanti zero-days to gain root on fully patched VPN appliances
Published 2026-10-14 · **B2** Usually reliable, probably true
Good summary of the chain. Gives July 2025 for release 25.1.3.0, against July 2026 elsewhere.

[S15] Canadian Centre for Cyber Security: Ivanti security advisory (AV26-1035), Update 2
Published 2026-10-13 · **A2** Completely reliable, probably true
Updated 2026-10-30. Lists versions before 25.1.1.3, 25.1.3.1 and 22.8R2.6 as affected.

[S16] Ampcus Cyber: CVE-2026-104935: Ivanti Connect Secure Zero-Day Chain Exploited for Root Access
Published 2026-10-15 · **C6** Fairly reliable, truth cannot be judged
Used only for the unlabeled SHA-256, which is uncorroborated. Also stated the escalation flaw had no CVE or fix at the time.

[S17] FIRST: EPSS API results for the three CVEs
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output. No score returned for CVE-2026-118527.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-09-30	Host 108.165.147[.]64 begins running an OpenVPN server, which continues until 2026-10-07.	[S2]
2026-10-01	Defused decoys record exploitation it assesses as CVE-2026-104935, before public disclosure.	[S10] [S11]
2026-10-03	Volexity's first observed UTA0576 exploitation.	[S2]
2026-10-05	Volexity begins investigating at a network security monitoring customer.	[S2]
2026-10-13	Ivanti discloses and patches CVE-2026-104935, Volexity publishes, and CISA adds it to KEV with a 2026-10-16 due date. The privilege escalation flaw remains unpatched.	[S2] [S4] [S11]
2026-10-14	Previdian honeypots reach 105 exploitation attempts from 50 addresses.	[S12]
2026-10-15	CVE record for CVE-2026-111357 published.	[S7]
2026-10-29	Ivanti updates its advisory and publishes the privilege escalation patch, adding CVE-2026-111357 and CVE-2026-118527.	[S2] [S9]
2026-10-30	CISA adds CVE-2026-111357 and CVE-2026-118527 to KEV.	[S4] [S5]
2026-11-02	Federal due date for CVE-2026-111357.	[S4]
2026-11-13	Federal due date for CVE-2026-118527.	[S4]
2027-01-31	Connect Secure 22.8 reaches end of life.	[S6]

Relevance to Indianapolis, Indiana & managed clients

We found no reporting that names an Indianapolis or Indiana victim, so the local risk comes from product use rather than known targeting. Any Indiana organization with an internet-facing Connect Secure appliance should treat this as relevant, and local governments, school districts, hospitals, clinics and manufacturers often use SSL VPNs for remote staff and vendors. The theft targets matter for these sectors: BitLocker recovery keys undercut laptop encryption that healthcare and education bodies often rely on to limit breach exposure, while LAPS passwords and sprayed domain accounts offer a fast path to servers and, at manufacturers, possibly toward plant-adjacent systems. Small and mid-size organizations are especially exposed because they may lack the

header logging and memory capture this triage needs, and they may have patched once in October and considered it done. Managed IT clients should get three things from their provider: a confirmed version per appliance, a written statement of what triage was done and on what evidence, and a decision on credential rotation. Providers should also check whether a shared appliance or service account links several client environments, because that would widen the impact of one compromise. Confirmed compromise may raise notification duties under Indiana's breach notification law and, for covered entities, HIPAA; counsel should make that call.

Intelligence gaps

- Ivanti's advisory could not be read because the page did not render, so the fixed-build list and per-CVE mapping need checking against it directly.
- The fixed build for the 25.1.2 branch is not confirmed. The status of 25.1.3.0 against the privilege escalation flaw also needs confirming, since it reportedly had only a partial fix and the Canadian Centre lists versions before 25.1.3.1 as affected.
- The CVE record for CVE-2026-118527 returned 404 and NVD pages did not render, so its 4.3 score rests on press reports. No EPSS score was returned.
- The number and sectors of victims are unknown. Ivanti gives only 'limited number', and Volexity describes one investigated customer.
- The true start of exploitation is unknown. Reporting points to as early as late September, and the actor's OpenVPN host was up on 2026-09-30.
- UTA0576's identity and goals are unknown, and whether stolen credentials were used for lateral movement in any victim network has not been reported. Volexity also says it has not established whether every cleanup step succeeded.
- Whether the honeypot sources seen by Previdian relate to UTA0576 or to other actors is unknown. Only 4 of the 50 addresses are published in the source we read, and Previdian's original data was not located.
- The SHA-256 in the Ampcus write-up has no stated origin or file name and could not be corroborated.
- Watch for: a public exploit or mass-exploitation reports, a Shadowserver count of unpatched devices, any ransomware link in KEV, a CISA or joint advisory with more IOCs, and a further Ivanti advisory revision.

Other notes

- Correction to the briefing excerpt: it says the RCE link has no CVE named in coverage. Volexity, The Hacker News's earlier coverage and Help Net Security place the bypass and RCE under CVE-2026-104935. The third listed CVE, CVE-2026-118527, describes the predictable upload location; we infer it relates to the same upload step [S2] [S4] [S14].
- CVSS disagreement for CVE-2026-111357: 8.8 in press reports of the advisory, and 7.0 with a local vector in the CVE record, which predates the advisory update. CWEs also differ: CWE-829 in the record, CWE-306, CWE-862 and CWE-345 in KEV. The CVE record also lists only 22.8R2.4 as affected [S1] [S4] [S7] [S9].
- Start-date disagreement: CyberScoop attributes the October 1 date to Volexity, while BleepingComputer and SecurityWeek attribute it to Defused and give Volexity's first date as October 3, matching Volexity's post. We follow the latter [S2] [S9] [S10] [S13].
- Version and history disagreement: Help Net Security gives July 2025 for release 25.1.3.0, while The Hacker News and SecurityWeek give July 2026. Sources also differ on whether the part Ivanti found internally belongs

to CVE-2026-104935 or to the privilege escalation flaw. CyberScoop reports Ivanti found it in June and judged it below the threshold for an out-of-band release [S1] [S9] [S13] [S14].

- 'Fully patched' means patched against what was known at the time. 22.8R2.4 falls in the affected range now listed for CVE-2026-104935 [S2] [S6].
- Federal scope: the CISA alert cites BOD 26-04, which applies only to federal civilian agencies but is encouraged for others. KEV's forensic triage field is Yes for CVE-2026-104935 and CVE-2026-111357 and No for CVE-2026-118527 [S4] [S5].
- Ivanti's guidance and CISA's differ in emphasis: Ivanti recommends running the Integrity Checker Tool regularly and reviewing Volexity's indicators, while CISA and Volexity warn that the tool may miss this chain. Run it, but do not rely on it [S2] [S6] [S13].
- Exposure counts from Shadowserver differ across reports (over 5,000 and over 5,500), and may include honeypots [S10] [S11].
- Watch for name collisions: the KEV catalog carried a malformed Ivanti URL in the CVE-2026-104935 notes, so use the advisory link from CISA's alert [S4] [S6].
- Context: this is reported as the 15th ICS or Pulse Connect Secure flaw on KEV, and BleepingComputer counts 38 Ivanti flaws flagged as exploited since November 2021, 12 used in ransomware [S10] [S12].

CTI-20261102-01 v1.0 · Generated 2026-11-02 10:40 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.